UNIT II ATTACKS AND COUNTERMEASURES

OSWAP; Malicious Attack Threats and Vulnerabilities: Scope of Cyber-Attacks – Security Breach – Types of Malicious Attacks – Malicious Software – Common Attack Vectors – Social engineering Attack – Wireless Network Attack – Web Application Attack – Attack Tools – Countermeasures.

2.1 OWASP

What is OWASP?

The Open Web Application Security Project, or OWASP, is an international non-profit organization dedicated to web application security. One of OWASP's core principles is that all of their materials be freely available and easily accessible on their website, making it possible for anyone to improve their own web application security. The materials they offer include documentation, tools, videos, and forums.

What is the OWASP Top 10?

The OWASP Top 10 is a regularly-updated report outlining security concerns for web application security, focusing on the 10 most critical risks. The report is put together by a team of security experts from all over the world. OWASP refers to the Top 10 as an 'awareness document' and they recommend that all companies incorporate the report into their processes in order to minimize and/or mitigate security risks.

1. Injection

Injection attacks happen when untrusted data is sent to a code interpreter through a form input or some other data submission to a web application. For example, an attacker could enter SQL database code into a form that expects a plaintext username. If that form input is not properly secured, this would result in that SQL code being executed. This is known as an SQL injection attack.

Injection attacks can be prevented by validating and/or sanitizing user-submitted data. (Validation means rejecting suspicious-looking data, while sanitization refers to cleaning up the suspicious-looking parts of the data.) In addition, a database admin can set controls to minimize the amount of information an injection attack can expose.

2. Broken Authentication

Vulnerabilities in authentication (login) systems can give attackers access to user accounts and even the ability to compromise an entire system using an admin account. For example, an attacker can take a list containing thousands of known username/password combinations obtained during a data breach and use a script to try all those combinations on a login system to see if there are any that work.

Some strategies to mitigate authentication vulnerabilities are requiring two-factor authentication (2FA) as well as limiting or delaying repeated login attempts using rate limiting.

3. Sensitive Data Exposure

If web applications don't protect sensitive data such as financial information and passwords, attackers can gain access to that data and sellor utilize it for nefarious purposes. One popular method for stealing sensitive information is using an on-path attack.

Data exposure risk can be minimized by encrypting all sensitive data as well as disabling the caching* of any sensitive information. Additionally, web application developers should take care to ensure that they are not unnecessarily storing any sensitive data.

*Caching is the practice of temporarily storing data for re-use. For example, web browsers will often cache webpages so that if a user revisits thosepages within a fixed time span, the browser does not have to fetch the pages from the web.

4. XML External Entities (XEE)

This is an attack against a web application that parses XML* input. This input can reference an external entity, attempting to exploit a vulnerability in the parser. An 'external entity' in this context refers to a storage unit, such as a hard drive. An XML parser can be duped into sending data to an unauthorized external entity, which can pass sensitive data directly to an attacker.

The best ways to prevent XEE attacks are to have web applications accept a less complex type of data, such as JSON**, or at the very least to patch XML parsers and disable the use of external entities in an XML application.

*XML or Extensible Markup Language is a markup language intended to be both human-readable and machine-readable. Due to its complexity and security vulnerabilities, it is now being phased out of use in many web applications.

**JavaScript Object Notation (JSON) is a type of simple, human-readable notation often used to transmit data over the internet. Although it was originally created for JavaScript, JSON is language-agnostic and can be interpreted by many different programming languages.

5. Broken Access Control

Access control refers a system that controls access to information or functionality. Broken access controls allow attackers to bypass authorization and perform tasks as though they were privileged users such as administrators. For example a web application could allow a user to change which account they are logged in as simply by changing part of a url, without any other verification.

Access controls can be secured by ensuring that a web application uses authorization tokens* and sets tight controls on them.

*Many services issue authorization tokens when users log in. Every privileged request that a user makes will require that the authorization token be present. This is a secure way to ensure that the user is who they say they are, without having to constantly enter their login credentials.

6. Security Misconfiguration

Security misconfiguration is the most common vulnerability on the list, and is often the result of using default configurations or displaying excessively verbose errors. For instance, an application could show a user overly-descriptive errors which may reveal vulnerabilities in the application. This can be mitigated by removing any unused features in the code and ensuring that error messages are more general.

7. Cross-Site Scripting

Cross-site scripting vulnerabilities occur when web applications allow users to add custom code into a url path or onto a website that will be seen by other users. This vulnerability can be exploited to run malicious JavaScript code on a victim's browser. For example, an attacker could send an email to a victim that appears to be from a trusted bank, with a link to that bank's website. This link could have some malicious JavaScript code tagged onto the end of the url. If the bank's site is not properly protected against cross-site scripting, then that malicious code will be run in the victim's web browser when they click on the link.

Mitigation strategies for cross-site scripting include escaping untrusted HTTP requests as well as validating and/or sanitizing user-generated content. Using modern web development frameworks like ReactJS and Ruby on Rails also provides some built-in cross-site scripting protection.

8. Insecure Deserialization

This threat targets the many web applications which frequently serialize and deserialize data. Serialization means taking objects from the application code and converting them into a format that can be used for another purpose, such as storing the data to disk or streaming it. Deserialization is just the opposite: converting serialized data back into objects the application can use. Serialization is sort of like packing furniture away into boxes before a move, and deserialization is like unpacking the boxes and assembling the furniture after the move. An insecure deserialization attack is like having the movers tamper with the contents of the boxes before they are unpacked.

An insecure deserialization exploit is the result of deserializing data from untrusted sources, and can result in serious consequences like DDoS attacks and remote code execution attacks. While steps can be taken to try and catch attackers, such as monitoring deserialization and implementing type checks, the only sure way to protect against insecure deserialization attacks is to prohibit the deserialization of data from untrusted sources.

9. Using Components With Known Vulnerabilities

Many modern web developers use components such as libraries and frameworks in their web applications. These components are pieces of software that help developers avoid redundant work and provide needed functionality; common example include front-end frameworks like React and smaller libraries that used to add share icons or a/b testing. Some attackers look for vulnerabilities in these components which they can then use to orchestrate attacks. Some of the more popular components are used on hundreds of thousands of websites; an attacker finding a security hole in one of these components could leave hundreds of thousands of sites vulnerable to exploit.

Component developers often offer security patches and updates to plug up known vulnerabilities, but web application developers don't always have the patched or most-recent versions of components running on their applications. To minimize the risk of running components with known vulnerabilities, developers should remove unused components from their projects, as well as ensuring that they are receiving components from a trusted source and ensuring they are up to date.

10. Insufficient Logging And Monitoring

Many web applications are not taking enough steps to detect data breaches. The average discovery time for a breach is around 200 days after it has happened. This gives attackers a lot of time to cause damage before there is any response. OWASP recommends that web developers should implement logging and monitoring as well as incident response plans to ensure that they are made aware of attacks on their applications.

2.2 Malicious attacks

An attack on a computer system or network asset succeeds by exploiting a vulnerability in the system. There are four general categories of attack. An attack can consist of all or a combination of these four categories:

Fabrications—Fabrications involve the creation of some deception in order to trick unsuspecting users.

Interceptions—An interception involves eavesdropping on transmissions and redirecting them for unauthorized use.

Interruptions—An interruption causes a break in a communication channel, which blocks the transmission of data.

• Modifications—A modification is the alteration of data contained in transmissions or files.

Threats

Threats can come from an individual, a group of individuals, or an organization. A threat to a computing device is any action, either accidental or malicious, that can have a negative effect

on the assets and resources of an individual or organization. The asset might be hardware, software, databases, files, data, or the physical network itself.

A threat is significant from a security viewpoint. The goal of computer security is to provide insights, methodologies, and techniques that deal with threats. You can achieve this goal by developing policies that help computer and network system administrators, designers, developers, and users avoid undesirable system characteristics and weaknesses.

You can identify threats and rank them according to their importance and impact. You can rank threats by their potential for dollar loss, negative reputation created, monetary liability, or how often they are likely to occur. Each organization may rank a threat higher or lower than another organization does based on its impact to that organization.

The most common threats, in no particular order, include the following:

- Malicious software
- Hardware or software failure
- Internal attacker
- Equipment theft
- External attacker
- Natural disaster
- Industrial espionage
- Terrorism

security threats can be active or passive. Both types can have negative repercussions for an IT infrastructure. An active attack involves a modification of the data stream or attempts to gain unauthorized access to computer and networking systems. An active attack is a physical intrusion. In a passive attack, the attacker does not make changes to the system. This type of attack simply eavesdrops on and monitors transmissions.

Active threats include the following:

- Birthday attacks
- Brute-force password attacks
- Dictionary password attacks
- IP address spoofing
- Hijacking
- Replay attacks
- Man-in-the-middle attacks
- Masquerading
- Social engineering
- Phishing
- Phreaking
- Pharming

Birthday Attacks

Once an attacker compromises a hashed password file, a birthday attack is performed. A birthday attack is a type of cryptographic attack that is used to make brute-force attack of one-way hashes easier. It is a mathematical exploit that is based on the birthday problem in probability theory.

Brute-Force Password Attacks

One of the most tried-and-true attack methods is the brute-force password attack. In a brute-force password attack, the attacker tries different passwords on a system until one of them is successful. Usually the attacker employs a software program to try all possible combinations of a likely password, user ID, or security code until it locates a match. This occurs rapidly and in sequence. This type of attack is called a *brute-force password attack* because the attacker simply hammers away at the code. There is no skill or stealth involved—just brute force that eventually breaks the code.

Dictionary Password Attacks

A *dictionary password attack* is a simple attack that relies on users making poor password choices. In a dictionary password attack, a simple password-cracker program takes all the words from a dictionary file and attempts to log on by entering each dictionary entry as a password.

Users often engage in the poor practice of selecting common words as passwords. A password policy that enforces complex passwords is the best defense against a dictionary password attack. Users should create passwords composed of a combination of letters and numbers, and the passwords should not include any personal information about the user.

IP Address Spoofing

Spoofing is a type of attack in which one person, program, or computer disguises itself as another person, program, or computer to gain access to some resource. A common spoofing attack involves presenting a false network address to pretend to be a different computer. An attacker may change a computer's network address to appear as an authorized computer in the target's network. If the administrator of the target's local router has not configured it to filter out external traffic with internal addresses, the attack may be successful. IP address spoofing can enable an attacker to access protected internal resources.

Address resolution protocol (ARP) poisoning is an example of a spoofing attack. In this attack, the attacker spoofs the MAC address of a targeted device, such as a server, by sending false ARP resolution responses with a different MAC address. This causes duplicate network traffic to be sent from the server. Another type of network-based attack is the Christmas (Xmas) attack. This type of attack sends advanced TCP packets with flags set to confuse IP routers and network border routers with TCP header bits set to 1, thus lighting up the IP router like a Christmas tree.

Hijacking

Hijacking is a type of attack in which the attacker takes control of a session between two machines and masquerades as one of them. There are a few types of hijacking:

Man-in-the-middle hijacking—In this type of hijacking, discussed in more detail in a moment, the attacker uses a program to take control of a connection by masquerading as each end of the connection. For example, if Mary and Fred want to communicate, the attacker pretends to be Mary when talking with Fred and pretends to be Fred when talking to Mary. Neither Mary nor Fred know they are talking to the attacker. The attacker can collect substantial information and can even alter data as they flow between Mary and Fred. This attack enables the attacker to either gain access to the messages or modify them before retransmitting. A man-in-the-middle attack can occur from an insider threat. An insider threat can occur from an employee, contractor, or trusted person within the organization.

Browser or URL hijacking—In a browser or URL hijacking attack, the user is directed to a different website than what he or she requested, usually to a fake page that the attacker

has created. This gives the user the impression that the attacker has compromised the website when in fact the attacker simply diverted the user's browser from the actual site. This type of attack is also known as typo squatting. Attackers can use this attack with phishing to trick a user into providing private information such as a password. (You'll learn about phishing in a moment.)

• **Session hijacking**—In session hijacking, the attacker attempts to take over an existing connection between two network computers. The first step in this attack is for the attacker to take control of a network device on the LAN, such as a firewall or another computer, in order to monitor the connection. This enables the attacker to determine the sequence numbers used by the sender and receiver. After determining the sequence numbering, the attacker generates traffic that appears to come from one of the communicating parties. This steals the session from one of the legitimate users. To get rid of the legitimate user who initiated the hijacked session, the attacker overloads one of the communicating devices with excess packets so that it drops out of the session.

Replay Attacks

Replay attacks involve capturing data packets from a network and retransmitting them to produce an unauthorized effect. The receipt of duplicate, authenticated IP packets may disrupt service or have some other undesired consequence. Systems can be broken through replay attacks when attackers reuse old messages or parts of old messages to deceive system users. This helps intruders to gain information that allows unauthorized access into a system.

Man-in-the-Middle Attacks

A man-in-the-middle attack takes advantage of the multihop process used by many types of networks. In this type of attack, an attacker intercepts messages between two parties before transferring them on to their intended destination.

Web spoofing is a type of man-in-the-middle attack in which the user believes a secure session exists with a particular web server. In reality, the secure connection exists only with the attacker, not the web server. The attacker then establishes a secure connection with the web server, acting as an invisible go-between. The attacker passes traffic between the user and the web server. In this way, the attacker can trick the user into supplying passwords, credit card information, and other private data.

Attackers use man-in-the-middle attacks to steal information, to execute DoS attacks, to corrupt transmitted data, to gain access to an organization's internal computer and network resources, and to introduce new information into network sessions.

Masquerading

In a masquerade attack, one user or computer pretends to be another user or computer. Masquerade attacks usually include one of the other forms of active attacks, such as IP address spoofing or replaying. Attackers can capture authentication sequences and then replay them later to log on again to an application or operating system. For example, an attacker might monitor usernames and passwords sent to a weak web application. The attacker could then use the intercepted credentials to log on to the web application and impersonate the user.

Eavesdropping

Eavesdropping, or sniffing, occurs when a host sets its network interface on promiscuous mode and copies packets that pass by for later analysis. Promiscuous mode enables a network device

to intercept and read each network packet, even if the packet's address doesn't match the network device. It is possible to attach hardware and software to monitor and analyze all packets on that segment of the transmission media without alerting any other users. Candidates for eavesdropping include satellite, wireless, mobile, and other transmission methods.

Social Engineering

Attackers often use a deception technique called social engineering to gain access to resources in an IT infrastructure. In nearly all cases, social engineering involves tricking authorized users into carrying out actions for unauthorized users. The success of social engineering attacks depends on the basic tendency of people to want to be helpful.

Social engineering places the human element in the security breach loop and uses it as a weapon. A forged or stolen vendor or employee ID could provide entry to a secure location. The intruder could then obtain access to important assets. By appealing to employees' natural instinct to help a technician or contractor, an attacker can easily breach the perimeter of an organization and gain access.

Eliminating social engineering attacks can be difficult, but here are some techniques to reduce their impact:
Ensure that employees are educated on the basics of a secure environment.
Develop a security policy and computer use policy.
Enforce a strict policy for internal and external technical support procedures.

Require the use of identification for all personnel.
• Limit the data accessible to the public by restricting the information published in directories, Yellow Pages, websites, and public databases.
• Be very careful when using remote access. Use strong validation so you know who is accessing your network.
• Teach personnel the techniques for sending and receiving secure email.
• Shred all documents that may contain confidential or sensitive information.

Phreaking

Phone phreaking, or simply phreaking, is a slang term that describes the activity of a subculture of people who study, experiment with, or explore telephone systems, telephone company equipment, and systems connected to public telephone networks. Phreaking is the art of exploiting bugs and glitches that exist in the telephone system.

Phishing

Fraud is a growing problem on the Internet. Phishing is a type of fraud in which an attacker attempts to trick the victim into providing private information such as credit card numbers, passwords, dates of birth, bank account numbers, automated teller machine (ATM) PINs, and Social Security numbers.

A phishing scam is an attempt to commit identity theft via email or instant message. The message appears to come from a legitimate source, such as a trusted business or financial institution, and includes an urgent request for personal information. Phishing messages usually indicate a critical need to update an account (banking, credit card, etc.) immediately. The message instructs the victim to either provide the requested information or click on a link provided in the message. Clicking the link leads the victim to a spoofed website. This website

looks identical to the official site but in fact belongs to the scammer. Personal information entered into this web page goes directly to the scammer, not to the legitimate organization.

A variation of the phishing attack is spear phishing. Spear phishing uses email or instant messages to target a specific organization, seeking unauthorized access to confidential data. As with the messages used in regular phishing attempts, spear-phishing messages appear to come from a trusted source.

Pharming

Pharming is another type of attack that seeks to obtain personal or private financial information through domain spoofing. A pharming attack doesn't use messages to trick victims into visiting spoofed websites that appear legitimate, however. Instead, pharming "poisons" a domain name on the domain name server (DNS), a process known as DNS poisoning. The result is that when a user enters the poisoned server's web address into his or her address bar, that user navigates to the attacker's site. The user's browser still shows the correct website, which makes pharming difficult to detect—and therefore more serious. Where phishing attempts to scam people one at a time with an email or instant message, pharming enables scammers to target large groups of people at one time through domain spoofing.

Threat Types

To secure information, you must protect its confidentiality, integrity, and availability (CIA). The three major threat types directly threaten each of the CIA tenets. They are as follows:

- Disclosure threats
- Alteration threats
- Denial or destruction threats

Disclosure Threats

Disclosure occurs any time unauthorized users access private or confidential information that is stored on a network resource or while it is in transit between network resources. Disclosure can also occur when a computer or device containing private or confidential data, such as a database of medical records, is lost or stolen. Two techniques that attackers employ to illegally obtain or modify data are as follows:

- Sabotage—Sabotage is the destruction of property or obstruction of normal operations. Technically, sabotage attacks the availability property of information security.
- Espionage—Espionage is the act of spying to obtain secret information, typically to aid another nation state. Terrorists and enemy agents might well be involved in activities to obtain sensitive government information that they can use to perpetuate future attacks.

Sabotage is not a silent attack, but espionage can occur without any obvious trace.

In many organizations, a great deal of stored information is unavailable to the public. This information can include personal information on a user's computer or confidential records stored in a massive database. The effects of the disclosure of this information can vary. For example, where the disclosure of a user's personal information could cause embarrassment, public disclosure of a citizen's private records could result in severe repercussions. In addition, disclosing information could cause even more problems if government secrets or intelligence files are involved.

Information security personnel devote much time and effort to combating disclosure threats. In particular, the U.S. government focuses very closely on disclosure threats because of their

potential to cause problems for critical security areas. One of the most difficult things about combating these types of threats, however, is that unauthorized users can intercept unprotected data without leaving any trace of their activities. For this reason, security research and development have focused on the disclosure threat and its countermeasures.

Alteration Threats

An alteration threat violates information integrity. This type of attack compromises a system by making unauthorized changes to data on a system, either intentionally or unintentionally. This change might occur while the data are stored on a network resource or while they are moving between two resources. Intentional changes are usually malicious. Unintentional changes are usually accidental. People can, and often do, make mistakes that affect the integrity of computer and network resources. Even so, unintentional changes still create security problems.

Denial or Destruction Threats

Denial or destruction threats make assets or resources unavailable or unusable. Any threat that destroys information or makes it unavailable violates the availability tenet of information security. A denial or destruction attack is successful when it prevents an authorized user from accessing a resource either temporarily or permanently.

A DoS attack is an example of a denial or destruction threat. As you learned earlier in this chapter, a DoS attack, which is usually malicious, prevents authorized users from accessing computer and network resources. Many organizations are potential victims of DoS attacks. In fact, any computer connected to the Internet is a DoS threat candidate. This type of attack can represent a minor problem or a great danger, depending on the importance of the blocked asset or resource. For example, suppose an attacker floods a specific port on a server. If the port is not for a critical resource, the impact may be minimal. However, if the port supports authorized user access to your company's website, it could prevent customers from accessing it for minutes or hours. In that case, the impact could be severe.

Vulnerabilities are the gaps or weaknesses in a system that make threats possible and tempt threat actors to exploit them.
Types of vulnerabilities in network security include but are not limited to SQL injections, server misconfigurations, cross-site scripting, and transmitting sensitive data in a non-encrypted plain text format.
When threat probability is multiplied by the potential loss that may result, cyber security experts, refer to this as a risk.

Categories of vulnerabilities
• Corrupted (Loss of integrity)

• Leaky (Loss of confidentiality)

• Unavailable or very slow (Loss of availability)

– Threats represent potential security harm to an asset when vulnerabilities are exploited

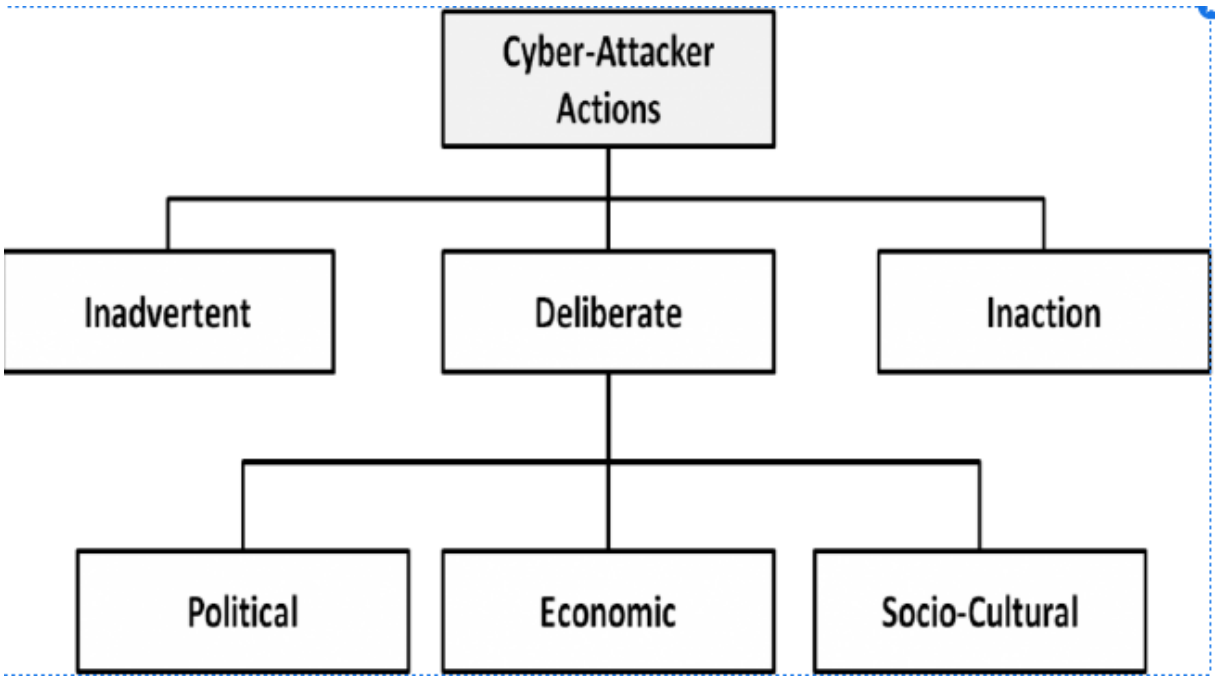
2.3 Scope of cyber attacks

The categories of cyber-attackers enable us to better understand the attackers' scope and the actions they take. As shown in Figure, operational cyber security risks arise from three types of actions: i) inadvertent actions (generally by insiders) that are taken without malicious or harmful intent; ii) deliberate actions (by insiders or outsiders) that are taken intentionally and are meant to do harm; and iii) inaction (generally by insiders), such as a failure to act in a given situation, either because of a lack of appropriate skills, knowledge, guidance, or availability of the correct person to take action Of primary concern here are deliberate actions, of which there are three categories of motivation.

1. ***Political motivations****:* examples include destroying, disrupting, or taking control of targets; espionage; and making political statements, protests, or retaliatory actions.

2. ***Economic motivations:*** examples include theft of intellectual property or other economically valuable assets (e.g., funds, credit card information); fraud; industrial espionage and sabotage; and blackmail.

3. ***Socio-cultural motivations:*** examples include attacks with philosophical, theological, political, and even humanitarian goals. Socio-cultural motivations also include fun, curiosity, and a desire for publicity or ego gratification.



2.4 Security breach

A security breach is any incident that results in unauthorized access to computer data, applications, networks or devices. It results in information being accessed without authorization. Typically, it occurs when an intruder is able to bypass security mechanisms.

Technically, there's a distinction between a security breach and a data breach. A security breach is effectively a break-in, whereas a data breach is defined as the cybercriminal getting away

with information. Imagine a burglar; the security breach is when he climbs through the window, and the data breach is when he grabs your pocketbook or laptop and takes it away.

Confidential information has immense value. It's often sold on the dark web; for example, names and credit card numbers can be bought, and then used for the purposes of identity theft or fraud. It's not surprising that security breaches can cost companies huge amounts of money. On average, the bill is nearly $4m for major corporations.

It's also important to distinguish the security breach definition from the definition of a security incident. An incident might involve a malware infection, DDOS attack or an employee leaving a laptop in a taxi, but if they don't result in access to the network or loss of data, they would not count as a security breach.

Examples of a security breach

When a major organization has a security breach, it always hits the headlines. Security breach examples include the following:

- Equifax - in 2017, a website application vulnerability caused the company to lose the personal details of 145 million Americans. This included their names, SSNs, and drivers' license numbers. The attacks were made over a three-month period from May to July, but the security breach wasn't announced until September.
- Yahoo - 3 billion user accounts were compromised in 2013 after a phishing attempt gave hackers access to the network.
- eBay saw a major breach in 2014. Though PayPal users' credit card information was not at risk, many customers' passwords were compromised. The company acted quickly to email its users and ask them to change their passwords in order to remain secure.
- Dating site Ashley Madison, which marketed itself to married people wishing to have affairs, was hacked in 2015. The hackers went on to leak a huge number of customer details via the internet. Extortionists began to target customers whose names were leaked; unconfirmed reports have linked a number of suicides to exposure by the data breach.
- Facebook saw internal software flaws lead to the loss of 29 million users' personal data in 2018. This was a particularly embarrassing security breach since the compromised accounts included that of company CEO Mark Zuckerberg.
- Marriott Hotels announced a security and data breach affecting up to 500 million customers' records in 2018. However, its guest reservations system had been hacked in 2016 - the breach wasn't discovered until two years later.
- Perhaps most embarrassing of all, being a cybersecurity firm doesn't make you immune - Czech company Avast disclosed a security breach in 2019 when a hacker managed to compromise an employee's VPN credentials. This breach didn't threaten customer details but was instead aimed at inserting malware into Avast's products.

A decade or so ago, many companies tried to keep news of security breaches secret in order not to destroy consumer confidence. However, this is becoming increasingly rare. In the EU, the GDPR (General Data Protection Regulations) require companies to notify the relevant

authorities of a breach and any individuals whose personal data might be at risk. By January 2020, GDPR had been in effect for just 18 months, and already, over 160,000 separate data breach notifications had been made - over 250 a day.

Types of security breaches

There are a number of types of security breaches depending on how access has been gained to the system:

- An exploit attacks a system vulnerability, such as an out of date operating system. Legacy systems which haven't been updated, for instance, in businesses where outdated and versions of Microsoft Windows that are no longer supported are being used, are particularly vulnerable to exploits.
- Weak passwords can be cracked or guessed. Even now, some people are still using the password 'password', and 'pa$$word' is not much more secure.
- Malware attacks, such as phishing emails can be used to gain entry. It only takes one employee to click on a link in a phishing email to allow malicious software to start spreading throughout the network.
- Drive-by downloads use viruses or malware delivered through a compromised or spoofed website.
- Social engineering can also be used to gain access. For instance, an intruder phones an employee claiming to be from the company's IT helpdesk and asks for the password in order to 'fix' the computer.

In the security breach examples we mentioned above, a number of different techniques were used to gain access to networks — Yahoo suffered a phishing attack, while Facebook was hacked by an exploit.

Though we've been talking about security breaches as they affect major organizations, the same security breaches apply to individuals' computers and other devices. You're probably less likely to be hacked using an exploit, but many computer users have been affected by malware, whether downloaded as part of a software package or introduced to the computer via a phishing attack. Weak passwords and use of public Wi-Fi networks can lead to internet communications being compromised.

What to do if you experience a security breach

As a customer of a major company, if you learn that it has had a security breach, or if you find out that your own computer has been compromised, then you need to act quickly to ensure your safety.
Remember that a security breach on one account could mean that other accounts are also at risk, especially if they share passwords or if you regularly make transactions between them.

- If a breach could involve your financial information, notify any banks and financial institutions with which you have accounts.

- Change the passwords on all your accounts. If there are security questions and answers or PIN codes attached to the account, you should change these too.
- You might consider a credit freeze. This stops anyone using your data for identity theft and borrowing in your name.
- Check your credit report to ensure you know if anyone is applying for debt using your details.
- Try to find out exactly what data might have been stolen. That will give you an idea of the severity of the situation. For instance, if tax details and SSNs have been stolen, you'll need to act fast to ensure your identity isn't stolen. This is more serious than simply losing your credit card details.
- Don'trespond directly to requests from a company to give them personal data after a data breach; it could be a social engineering attack. Take the time to read the news, check the company's website, or even phone their customer service line to check if the requests are legitimate.
- Be on your guard for other types of social engineering attacks. For instance, a criminal who has accessed a hotel's accounts, even without financial data, could ring customers asking for feedback on their recent stay. At the end of the call, having established a relationship of trust, the criminal could offer a refund of parking charges and ask for the customer's card number in order to make the payment. Most customers probably wouldn't think twice about providing those details if the call is convincing.
- Monitor your accounts for signs of any new activity. If you see transactions that you don't recognize, address them immediately.

How to protect yourself against a security breach

Although no one is immune to a data breach, good computer security habits can make you less vulnerable and can help you survive a breach with less disruption. These tips should help you prevent hackers breaching your personal security on your computers and other devices.

- Use strong passwords, which combine random strings of upper and lower-case letters, numbers, and symbols. They are much more difficult to crack than simpler passwords. Don't use passwords that are easy to guess, like family names or birthdays. Use a Password Manager to keep your passwords secure.
- Use different passwords on different accounts. If you use the same password, a hacker who gains access to one account will be able to get into all your other accounts. If they have different passwords, only that one account will be at risk.
- Close accounts you don't use rather than leaving them dormant. That reduces your vulnerability to a security breach. If you don't use an account, you might never realize that it has been compromised, and it could act as a back door to your other accounts.
- Change your passwords regularly. One feature of many publicly reported security breaches is that they occurred over a long period, and some were not reported until years after the breach. Regular password changes reduce the risk you run from unannounced data breaches.

- If you throw out a computer, wipe the old hard drive properly. Don't just delete files; use a data destruction program to wipe the drive completely, overwriting all the data on the disk. Creating a fresh installation of the operating system will also wipe the drive successfully.
- Back up your files. Some data breaches lead to the encryption of files and a ransomware demand to make them available again to the user. If you have a separate backup on a removable drive, your data is safe in the event of a breach.
- Secure your phone. Use a screen lock and update your phone's software regularly. Don’t root or jailbreak your phone. Rooting a device gives hackers the opportunity to install their own software and to change the settings on your phone.
- Secure your computer and other devices by using anti-virus and anti-malware software. Kaspersky Antivirus is a good choice to keep your computer free from infection and ensure that hackers can't get a foothold in your system.
- Be careful where you click. Unsolicited emails which include links to websites may be phishing attempts. Some may purport to be from your contacts. If they include attachments or

  links, ensure they're genuine before you open them and use an anti-virus program on attachments.
- When you're accessing your accounts, make sure you're using the secure HTTPS protocol and not just HTTP.
- Monitoring your bank statements and credit reports helps keep you safe. Stolen data can turn up on the dark web years after the original data breach. This could mean an identity theft attempt occurs long after you've forgotten the data breach that compromised that account.
- Know the value of your personal information and don't give it out unless necessary. Too many websites want to know too much about you; why does a business journal need your exact date of birth, for instance? Or an auction site your SSN?

  You'd never dream of leaving your house door open all day for anyone to walk in. Think of your computer the same way. Keep your network access and your personal data tightly secured, and don't leave any windows or doors open for a hacker to get through.

2.5 Types of malicious attacks

Any malicious software intended to harm or exploit any programmable device, service, or network is referred to as malware. Cybercriminals typically use it to extract data they can use against victims to their advantage in order to profit financially. Financial information, medical records, personal emails, and passwords are just a few examples of the types of information that could be compromised.

In simple words, malware is short for malicious software and refers to any software that is designed to cause harm to computer systems, networks, or users. Malware can take many forms. It’s important for individuals and organizations to be aware of the different types of malware and take steps to protect their systems, such as using antivirus software, keeping software and systems up-to-date, and being cautious when opening email attachments or downloading software from the internet.

Malware is a program designed to gain access to computer systems, generally for the benefit of some third party, without the user's permission. Malware includes computer viruses, worms, Trojan horses, ransomware, spyware, and other malicious programs.

Types of Malware

1. Viruses – A Virus is a malicious executable code attached to another executable file. The virus spreads when an infected file is passed from system to system. Viruses can be harmless or they can modify or delete data. Opening a file can trigger a virus. Once a program virus is active, it will infect other programs on the computer.
2. Worms – Worms replicate themselves on the system, attaching themselves to different files and looking for pathways between computers, such as computer network that shares common file storage areas. Worms usually slow down networks. A virus needs a host program to run but worms can run by themselves. After a worm affects a host, it is able to spread very quickly over the network.
3. Trojan horse – A Trojan horse is malware that carries out malicious operations under the appearance of a desired operation such as playing an online game. A Trojan horse varies from a virus because the Trojan binds itself to non-executable files, such as image files, and audio files.
4. Ransomware – Ransomware grasps a computer system or the data it contains until the victim makes a payment. Ransomware encrypts data in the computer with a key that is unknown to the user. The user has to pay a ransom (price) to the criminals to retrieve data. Once the amount is paid the victim can resume using his/her system
5. Adware – It displays unwanted ads and pop-ups on the computer. It comes along with software downloads and packages. It generates revenue for the software distributer by displaying ads.
6. Spyware – Its purpose is to steal private information from a computer system for a third party. Spyware collects information and sends it to the hacker.
7. Logic Bombs – A logic bomb is a malicious program that uses a trigger to activate the malicious code. The logic bomb remains non-functioning until that trigger event happens. Once triggered, a logic bomb implements a malicious code that causes harm to a computer. Cybersecurity specialists recently discovered logic bombs that attack and destroy the hardware components in a workstation or server including the cooling fans, hard drives, and power supplies. The logic bomb overdrives these devices until they overheat or fail.
8. Rootkits – A rootkit modifies the OS to make a backdoor. Attackers then use the backdoor to access the computer distantly. Most rootkits take advantage of software vulnerabilities to modify system files.
9. Backdoors – A backdoor bypasses the usual authentication used to access a system. The purpose of the backdoor is to grant cyber criminals future access to the system even if the organization fixes the original vulnerability used to attack the system.
10. Keyloggers – Keylogger records everything the user types on his/her computer system to obtain passwords and other sensitive information and send them to the source of the keylogging

program.

2.6 Malwares – Malicious Software

Malware is a software that gets into the system without user consent with an intention to steal private and confidential data of the user that includes bank details and password. They also generates annoying pop up ads and makes changes in system settings
They get into the system through various means:

1. Along with free downloads.
2. Clicking on suspicious link.
3. Opening mails from malicious source.
4. Visiting malicious websites.
5. Not installing an updated version of antivirus in the system.

Types:

1. Virus
2. Worm
3. Logic Bomb
4. Trojan/Backdoor
5. Rootkit
6. Advanced Persistent Threat
7. Spyware and Adware

What is computer virus:
Computer virus refers to a program which damages computer systems and/or destroys or erases data files. A computer virus is a malicious program that self-replicates by copying itself to another program. In other words, the computer virus spreads by itself into other executable code or documents. The purpose of creating a computer virus is to infect vulnerable systems, gain admin control and steal user sensitive data. Hackers design computer viruses with malicious intent and prey on online users by tricking them.

Symptoms:

- Letter looks like they are falling to the bottom of the screen.
- The computer system becomes slow.
- The size of available free memory reduces.
- The hard disk runs out of space.
- The computer does not boot.

Types of Computer Virus:

These are explained as following below.

1. Parasitic –
   These are the executable (.COM or .EXE execution starts at first instruction). Propagated by attaching itself to particular file or program. Generally resides at the start (prepending) or at the end (appending) of a file, e.g. Jerusalem.

2. Boot Sector –
   Spread with infected floppy or pen drives used to boot the computers. During system boot, boot sector virus is loaded into main memory and destroys data stored in hard disk, e.g. Polyboot, Disk killer, Stone, AntiEXE.

3. Polymorphic –
   Changes itself with each infection and creates multiple copies. Multipartite: use more than one propagation method. >Difficult for antivirus to detect, e.g. Involutionary, Cascade, Evil, Virus 101., Stimulate.

   Three major parts: Encrypted virus body, Decryption routine varies from infection to infection, and Mutation engine.

4. Memory Resident –
   Installs code in the computer memory. Gets activated for OS run and damages all files opened at that time, e.g. Randex, CMJ, Meve.

5. Stealth –
   Hides its path after infection. It modifies itself hence difficult to detect and masks the size of infected file, e.g. Frodo, Joshi, Whale.

6. Macro –
   Associated with application software like word and excel. When opening the infected document, macro virus is loaded into main memory and destroys the data stored in hard disk.

   As attached with documents; spreads with those infected documents only, e.g. DMV, Melissa, A, Relax, Nuclear, Word Concept.

7. Hybrids –
   Features of various viruses are combined, e.g. Happy99 (Email virus).

   Worm:
   A worm is a destructive program that fills a computer system with self-replicating information, clogging the system so that its operations are slowed down or stopped.

   Types of Worm:

1. Email worm – Attaching to fake email messages.
2. Instant messaging worm – Via instant messaging applications using loopholes in network.
3. Internet worm – Scans systems using OS services.
4. Internet Relay Chat (IRC) worm – Transfers infected files to web sites.
5. Payloads – Delete or encrypt file, install backdoor, creating zombie etc.
6. Worms with good intent – Downloads application patches.

Logical Bomb:
A logical bomb is a destructive program that performs an activity when a certain action has occurred. These are hidden in programming code. Executes only when a specific condition is met.
Script Virus:
Commonly found script viruses are written using the Visual Basic Scripting Edition (VBS) and the JavaScript programming language.

Trojan / Backdoor:
Trojan Horse is a destructive program. It usually pretends as computer games or application software. If executed, the computer system will be damaged. Trojan Horse usually comes with monitoring tools and key loggers. These are active only when specific events are alive. These are hidden with packers, crypters and wrappers.< Hence, difficult to detect through antivirus. These can use manual removal or firewall precaution.

RootKits:
Collection of tools that allow an attacker to take control of a system.

- Can be used to hide evidence of an attacker's presence and give them backdoor access.
- Can contain log cleaners to remove traces of attacker.
- Can be divided as:
  – Application or file rootkits: replaces binaries in Linux system
  – Kernel: targets kernel of OS and is known as a loadable kernel module (LKM)
- Gains control of infected m/c by:
  – DLL injection: by injecting malicious DLL (dynamic link library)
  – Direct kernel object manipulation: modify kernel structures and directly target trusted part of OS
  – Hooking: changing applicant's execution flow

Advanced Persistent Threat:
Created by well funded, organized groups, nation-state actors, etc. Desire to compromise government and commercial entities, e.g. Flame: used for reconnaissance and information gathering of system.

Spyware and Adware:
Normally gets installed along with free software downloads. Spies on the end-user, attempts to redirect the user to specific sites. Main tasks: Behavioral surveillance and advertising with pop up ads Slows down the system.

2.7 Common attack vectors

In cybersecurity, an attack vector is a method of achieving unauthorized network access to launch a cyber attack. Attack vectors allow cybercriminals to exploit system vulnerabilities to gain access
to sensitive data, personally identifiable information (PII), and other valuable information accessible after a data breach.

An attack vector is a method of gaining unauthorized access to a network or computer system.

An attack surface is the total number of attack vectors an attacker can use to manipulate a network or computer system or extract data.

Threat vector can be used interchangeably with attack vector and generally describes the potential ways a hacker can gain access to data or other confidential information.

Examples

1. **Compromised Credentials**

   Usernames and passwords are still the most common type of access credential and continue to be exposed in data leaks, phishing scams, and malware. When lost, stolen, or exposed, credentials give attackers unfettered access. This is why organizations are now investing in tools to continuously monitor for data exposures and leaked credentials. Password managers, two-factor
   authentication (2FA), multi-factor authentication (MFA), and biometrics can reduce the risk of leak credentials resulting in a security incident too.

2. **Weak Credentials**

   Weak passwords and reused passwords mean one data breach can result in many more. Teach your organization how to create a secure password, invest in a password manager or a single sign-on tool, and educate staff on their benefits.

3. **Insider Threats**

   Disgruntled employees or malicious insiders can expose private information or provide information about company-specific vulnerabilities.

4. **Missing or Poor Encryption**

   Common data encryption methods like SSL certificates and DNSSEC can prevent man-in-the-middle attacks and protect the confidentiality of data being transmitted. Missing or poor encryption for data at rest can mean that sensitive data or credentials are exposed in the event of a data breach or data leak.

5. **Misconfiguration**
   Misconfiguration of cloud services, like Google Cloud Platform, Microsoft Azure, or AWS, or using default credentials can lead to data breaches and data leaks, check your S3 permissions or someone else will. Automate configuration management where possible to prevent configuration drift.

6. **Ransomware**

   Ransomware is a form of extortion where data is deleted or encrypted unless a ransom is paid, such as WannaCry. Minimize the impact of ransomware attacks by maintaining a defense plan, including keeping your systems patched and backing up important data.

7. **Phishing**

   Phishing attacks are social engineering attacks where the target is contacted by email, telephone, or text message by someone who is posing to be a legitimate colleague or institution

to trick them into providing sensitive data, credentials, or personally identifiable information (PII). Fake messages can send users to malicious websites with viruses or malware payloads.

8. **Vulnerabilities**

   New security vulnerabilities are added to the CVE every day and zero-day vulnerabilities are found just as often. If a developer has not released a patch for a zero-day vulnerability before an attack can exploit it, it can be hard to prevent zero-day attacks.

9. **Brute Force**

   Brute force attacks are based on trial and error. Attackers may continuously try to gain access to your organization until one attack works. This could be by attacking weak passwords or encryption, phishing emails, or sending infected email attachments containing a type of malware.

10. **Distributed Denial of Service (DDoS)**

    DDoS attacks are cyber attacks against networked resources like data centers, servers, websites, or web applications and can limit the availability of a computer system. The attacker floods the network resource with messages which cause it to slow down or even crash, making it inaccessible to users. Potential mitigations include CDNs and proxies.

11. **SQL Injections**

    SQL stands for a structured query language, a programming language used to communicate with databases. Many of the servers that store sensitive data use SQL to manage the data in their database. An SQL injection uses malicious SQL to get the server to expose information it otherwise wouldn't. This is a huge cyber risk if the database stores customer information, credit card numbers, credentials, or other personally identifiable information (PII).

12. **Trojans**

    Trojan horses are malware that misleads users by pretending to be a legitimate program and are often spread via infected email attachments or fake malicious software.

13. **Cross-Site Scripting (XSS)**

    XSS attacks involve injecting malicious code into a website but the website itself is not being attacked, rather it aims to impact the website's visitors. A common way attackers can deploy cross-site scripting attacks is by injecting malicious code into a comment e.g. embedding a link to malicious JavaScript in a blog post's comment section.

14. **Session Hijacking**

    When you log into a service, it generally provides your computer with a session key or cookie so you don't need to log in again. This cookie can be hijacked by an attacker who uses it to gain access to sensitive information.

15. **Man-in-the-Middle Attacks**

    Public Wi-Fi networks can be exploited to perform man-in-the-middle attacks and intercept traffic that was supposed to go elsewhere, such as when you log into a secure system.

16. **Third and Fourth-Party Vendors**

The rise in outsourcing means that your vendors pose a huge cybersecurity risk to your customer's data and your proprietary data. Some of the biggest data breaches were caused by third parties.

How Do Hackers Exploit Attack Vectors?

Hackers use multiple threat vectors to exploit vulnerable systems, attack devices and networks, and steal data from individuals. There are two main types of hacker vector attacks: passive attacks and active attacks.

Passive Attack

A passive attack occurs when an attacker monitors a system for open ports or vulnerabilities to gain or gather information about their target. Passive attacks can be difficult to detect because they do not involve altering data or system resources. Rather than cause damage to an organization's systems, the attacker threatens the confidentiality of their data.

Passive attack vectors include passive reconnaissance, which sees the attacker monitor an organization's systems for vulnerabilities without interacting with them through tools like session capture, and active reconnaissance, where the attacker uses methods like port scans to engage with target systems.

Active Attack

An active attack vector is one that sets out to disrupt or cause damage to an organization's system resources or affect their regular operations. This includes attackers launching attacks against system vulnerabilities, such as denial-of-service (DoS) attacks, targeting users' weak passwords, or through malware and phishing attacks.

A common example of an active attack is a masquerade attack, in which an intruder pretends to be a trusted user and steals login credentials to gain access privileges to system resources. Active attack methods are often used by cyber criminals to gain the information they need to launch a wider cyberattack against an organization.

2.8 Social engineering attack

Social engineering is an attack vector that relies heavily on human interaction and often involves manipulating people into breaking normal security procedures and best practices to gain unauthorized access to systems, networks or physical locations or for financial gain.

Threat actors use social engineering techniques to conceal their true identities and motives, presenting themselves as trusted individuals or information sources. The objective is to influence, manipulate or trick users into releasing sensitive information or access within an organization. Many social engineering exploits rely on people's willingness to be helpful or fear of punishment. For example, the attacker might pretend to be a co-worker who has some kind of urgent problem that requires access to additional network resources.

Social engineering is a popular tactic among attackers because it is often easier to exploit people than it is to find a network or software vulnerability. Hackers will often use social engineering tactics as a first step in a larger campaign to infiltrate a system or network and steal sensitive data or disperse malware.

A social engineering attack is a cybersecurity attack that relies on the psychological manipulation of human behavior to disclose sensitive data, share credentials, grant access to a personal device or otherwise compromise their digital security.

Social engineering attacks pose a great threat to cybersecurity since many attacks begin on a personal level and rely on human error to advance the attack path. By invoking empathy, fear and urgency in the victim, adversaries are often able to gain access to personal information or the endpoint itself. If the device is connected to a corporate network or contains credentials for corporate accounts, this can also provide adversaries with a pathway to enterprise-level attacks.

With cyber criminals devising ever-more manipulative methods for tricking people and employees, organizations must stay ahead of the game. In this post, we will explore ten of the most common types of social engineering attacks:

1. Phishing
2. Whaling
3. Baiting
4. Diversion Theft
5. Business Email Compromise (BEC)
6. Smishing
7. Quid Pro Quo
8. Pretexting
9. Honeytrap
10. Tailgating/Piggybacking

- Baiting. An attacker leaves a malware-infected physical device, such as a Universal Serial Bus flash drive, in a place it is sure to be found. The target then picks up the device and inserts it into their computer, unintentionally installing the malware.
- Phishing. When a malicious party sends a fraudulent email disguised as a legitimate email, often purporting to be from a trusted source. The message is meant to trick the recipient into sharing financial or personal information or clicking on a link that installs malware.
- Spear phishing. This is like phishing, but the attack is tailored for a specific individual or organization.
- Vishing. Also known as voice phishing, vishing involves the use of social engineering over the phone to gather financial or personal information from the target.
- Whaling. A specific type of phishing attack, a whaling attack targets high-profile employees, such as the chief financial officer or chief executive officer, to trick the targeted employee into disclosing sensitive information.

- Pretexting. One party lies to another to gain access to privileged data. For example, a pretexting scam could involve an attacker who pretends to need financial or personal data to confirm the identity of the recipient.
- Scareware. This involves tricking the victim into thinking their computer is infected with malware or has inadvertently downloaded illegal content. The attacker then offers the victim a solution that will fix the bogus problem; in reality, the victim is simply tricked into downloading and installing the attacker's malware.
- Watering hole. The attacker attempts to compromise a specific group of people by infecting websites they are known to visit and trust with the goal of gaining network access.
- Diversion theft. In this type of attack, social engineers trick a delivery or courier company into going to the wrong pickup or drop-off location, thus intercepting the transaction.
- Quid pro quo. This is an attack in which the social engineer pretends to provide something in exchange for the target's information or assistance. For instance, a hacker calls a selection of random numbers within an organization and pretends to be a technical support specialist responding to a ticket. Eventually, the hacker will find someone with a legitimate tech issue whom they will then pretend to help. Through this interaction, the hacker can have the target type in the commands to launch malware or can collect password information.
- Honey trap. In this attack, the social engineer pretends to be an attractive person to interact with a person online, fake an online relationship and gather sensitive information through that relationship.
- Tailgating. Sometimes called piggybacking, tailgating is when a hacker walks into a secured building by following someone with an authorized access card. This attack presumes the person with legitimate access to the building is courteous enough to hold the door open for the person behind them, assuming they are allowed to be there.
- Rogue security software. This is a type of malware that tricks targets into paying for the fake removal of malware.
- Dumpster diving. This is a social engineering attack whereby a person searches a company's trash to find information, such as passwords or access codes written on sticky notes or scraps of paper, that could be used to infiltrate the organization's network.
- Pharming. With this type of online fraud, a cybercriminal installs malicious code on a computer or server that automatically directs the user to a fake website, where the user may be tricked into providing personal information.

Preventing social engineering

There are a number of strategies companies can take to prevent social engineering attacks, including the following:

- Make sure information technology departments are regularly carrying out penetration testing

that uses social engineering techniques. This will help administrators learn which types of users pose the most risk for specific types of attacks, while also identifying which employees require additional training.

- Start a security awareness training program, which can go a long way toward preventing social engineering attacks. If users know what social engineering attacks look like, they will be less likely to become victims.
- Implement secure email and web gateways to scan emails for malicious links and filter them out, thus reducing the likelihood that a staff member will click on one.
- Keep antimalware and antivirus software up to date to help prevent malware in phishing emails from installing itself.
- Stay up to date with software and firmware patches on endpoints.
- Keep track of staff members who handle sensitive information, and enable advanced authentication measures for them.
- Implement 2FA to access key accounts, e.g., a confirmation code via text message or voice recognition.
- Ensure employees don't reuse the same passwords for personal and work accounts. If a hacker perpetrating a social engineering attack gets the password for an employee's social media account, the hacker could also gain access to the employee's work accounts.
- Implement spam filters to determine which emails are likely to be spam. A spam filter might have a blacklist of suspicious Internet Protocol addresses or sender IDs, or they might detect suspicious files or links, as well as analyze the content of emails to determine which may be fake.

2.9 Wireless Network Attacks

Wireless network attacks are deliberate and malicious actions aimed at exploiting vulnerabilities in wireless communication systems to gain unauthorized access, intercept sensitive data, disrupt network operations, or compromise the security of devices and users connected to the network. These attacks target weaknesses in the protocols, configurations, or encryption mechanisms of wireless networks, taking advantage of their inherent nature of broadcasting signals over the airwaves.

Types of Wireless Network Attacks

Wireless networks have undoubtedly revolutionized the way we communicate and conduct business, offering unparalleled convenience and mobility. However, with this freedom comes the lurking threat of malicious attackers seeking to exploit the vulnerabilities inherent in wireless technology. Here are some of the common types of wireless network attacks:

1. **Wireless Eavesdropping (Passive Attacks)**

Attackers use tools like packet sniffers to intercept and monitor wireless communications between devices. By capturing data packets transmitted over the air, they can potentially obtain sensitive information, such as login credentials, financial data, or personal information.

2. **Wireless Spoofing (Man-in-the-Middle Attacks)**

   In these attacks, the attacker positions themselves between the wireless client and the legitimate access point, intercepting and manipulating data transmissions. The attacker may then relay the information back and forth, making it appear as if they are the legitimate access point. This enables them to snoop on data or perform other malicious actions unnoticed.

3. **Wireless Jamming (Denial-of-Service Attacks)**

   Attackers flood the wireless frequency spectrum with interference signals, disrupting legitimate communications between devices and access points. By creating excessive noise, they can render the wireless network unusable for legitimate users.

4. **Rogue Access Points**

   Attackers set up unauthorized access points, mimicking legitimate ones, to deceive users into connecting to them. Once connected, the attacker can eavesdrop, capture data, or launch further attacks on the unsuspecting users.

5. **Brute-Force Attacks**

   Attackers try various combinations of passwords or encryption keys in rapid succession until they find the correct one to gain unauthorized access to the wireless network.

6. **WEP/WPA Cracking**

   Attackers exploit vulnerabilities in older wireless security protocols like Wired Equivalent Privacy (WEP) and Wi-Fi Protected Access (WPA) to gain unauthorized access to encrypted wireless networks.

7. **Evil Twin Attacks**

   Attackers create fake access points with names similar to legitimate ones, tricking users into connecting to the malicious network. Once connected, the attacker can intercept sensitive data or execute further attacks.

8. **Deauthentication/Disassociation Attacks**

   Attackers send forged deauthentication or disassociation frames to wireless devices, forcing them to disconnect from the network, leading to service disruptions or potential vulnerabilities when devices automatically reconnect.

Preventing Wireless Network Attacks: Safeguarding Your Digital Domain

Protecting your wireless network from potential threats is paramount, and we have compiled a comprehensive list of preventive measures to ensure your digital domain remains secure. Follow these essential tips to fortify your wireless network against attacks:

1. **Update your computer often**

   Regularly update your operating system and applications to ensure you have the latest security patches and fixes. Timely updates help address discovered vulnerabilities, making it harder for attackers to exploit known weaknesses.

2. **Use MAC filtering**

   Enable MAC filtering on your wireless router to control access to your network. By specifying which devices are allowed to connect based on their unique MAC addresses, you can prevent unauthorized access and enhance your network's security.

3. **Disable SSID broadcasting**

   Turn off SSID broadcasting to make your wireless network invisible to casual observers. This prevents your network from being easily discoverable and adds an extra layer of obscurity for potential attackers.

4. **Use WPA2 encryption**

   Utilize WPA2 encryption, the latest and most secure protocol, to safeguard your data as it travels between devices and access points. Encryption ensures that even if intercepted, your data remains unintelligible to unauthorized entities.

5. **Change the default SSID**

   Customize your router's SSID to something unique and unrelated to personal information. Avoid using common names like "Linksys" or "default" to deter attackers from identifying and targeting your network.

6. **Disable file sharing**

   Turn off file sharing on your network to prevent unauthorized users from accessing your sensitive files. If file sharing is necessary, ensure you set up secure passwords to limit access to approved users only.

7. **Enable WEP encryption (only if using an older router)**

   If your router doesn't support WPA2, use WEP encryption as a fallback option. However, keep in mind that WEP is less secure than WPA2 and should only be considered if absolutely necessary.

2.10 Web Application Attacks

Web application attacks are malicious activities that target web applications by exploiting vulnerabilities in their design or implementation. These attacks can result in unauthorized access, data theft, or other harmful consequences.

Common types of web application attacks include SQL injection, cross-site scripting (XSS), cross-site request forgery (CSRF), and file inclusion attacks. Attackers may use automated tools or manually craft their attacks to bypass security measures and gain access to sensitive information or systems.

Organizations can prevent or mitigate web application attacks by implementing strong security measures, such as input validation, user authentication, and regular vulnerability testing.

Common Types of Web Application Attacks

1. **Cross-Site Scripting (XSS)**

Cross-site scripting (XSS) is a type of web application attack that involves injecting malicious scripts into web pages that are viewed by other users. This is typically accomplished by injecting the script into a form input field or URL parameter that is then stored in the web application's database.

When another user views the page that contains the malicious script, the script is executed in their browser, allowing the attacker to steal data or perform other malicious actions on the user's behalf. XSS attacks can be prevented by properly sanitizing user input, using content security policy (CSP) headers, and escaping untrusted data.

2. Cross-Site Request Forgery (CSRF)

Cross-site request forgery (CSRF) is a type of web application attack that tricks a user into executing an unwanted action on a web application that they are already authenticated with. This is typically accomplished by sending a specially crafted link or script to the user, which then performs the unwanted action when clicked.

For example, a CSRF attack could be used to make unauthorized purchases or change account settings. CSRF attacks can be prevented by using anti-CSRF tokens, which are unique tokens that are generated by the web application for each user session and must be included in every request to the application.

3. XML External Entity (XXE)

XML External Entity (XXE) is a type of web application attack that involves exploiting vulnerabilities in XML parsers used by a web application. This can allow an attacker to read sensitive data or execute unauthorized actions on the web application's server.

XXE attacks typically involve injecting specially crafted XML payloads that exploit the XML parser's ability to read external entities. XXE attacks can be prevented by disabling external entity parsing or using secure XML parsers that properly sanitize input data.

4. Injection Attacks

Injection attacks involve inserting malicious code into a web application, typically in the form of input data such as SQL queries, commands, or scripts. Injection attacks are successful when an application fails to properly validate and sanitize input data. These attacks can be prevented by properly validating and sanitizing input data and using parameterized queries to access databases.

5. Fuzz Testing (Fuzzing)

Fuzz testing, also known as fuzzing, is a technique used to discover vulnerabilities in a web application by sending it random or invalid input data. The goal of fuzz testing is to identify how the web application responds to different inputs and to find errors and crashes.

Fuzz testing can be performed manually or with the help of automated tools. Fuzz testing can uncover vulnerabilities that may not be detected by other security testing methods such as penetration testing. To perform effective fuzz testing, a tester needs to understand the web application's input and output mechanisms and the types of data that the application processes.

6. DDoS (Distributed Denial-of-Service)

A Distributed Denial-of-Service (DDoS) attack is a type of web application attack that involves overwhelming a web application with a large volume of traffic from multiple sources, such as botnets or compromised devices. This can cause the web application to become unavailable to legitimate users.

DDoS attacks can be prevented by using network security devices, such as firewalls and intrusion prevention systems, that can detect and block malicious traffic. Additionally, web application developers can use content delivery networks (CDNs) and load balancers to distribute traffic across multiple servers to help mitigate the effects of DDoS attacks.

7. **Brute Force Attack**

A brute force attack is an automated method of guessing a username and password combination to gain unauthorized access to a web application. Attackers use software tools to try different combinations of usernames and passwords until they successfully guess the correct one.

To prevent brute force attacks, web applications can implement rate-limiting and account lockout policies. Rate-limiting limits the number of login attempts from a single IP address, while account lockout temporarily blocks access to an account after a certain number of failed login attempts.

8. **Path Traversal**

Path traversal is a type of web application attack that involves manipulating file paths in a web application in order to access unauthorized files or directories on the server. Path traversal attacks typically occur when a web application does not properly validate user input, allowing an attacker to traverse up and down directory structures to access sensitive files.

Path traversal attacks can be prevented by properly validating user input and sanitizing file paths, as well as using secure file access methods that restrict access to sensitive files and directories.

Web Application Security Strategies

Here are some web application security strategies that organizations can implement to protect their web applications:

- Secure coding practices: Adopt secure coding practices, such as the OWASP Top 10 guidelines, to ensure that web applications are built with security in mind. This includes measures like input validation, output encoding, and secure authentication mechanisms.
- Regular security testing: Perform regular security testing, such as penetration testing and vulnerability scanning, to identify and address security vulnerabilities in web applications.
- Access control: Implement access controls to ensure that only authorized users can access sensitive data or functionality within web applications. This includes measures like role-based access control and multi-factor authentication.
- Secure communication: Use secure communication protocols, such as HTTPS, to ensure that data transmitted between web applications and users is encrypted and protected from interception.

- Server and network security: Implement server and network security measures, such as firewalls and intrusion detection systems, to protect web applications from attacks like DDoS and SQL injection.
- Regular updates and patches: Keep web applications and supporting software up-to-date with the latest security patches and updates to address known vulnerabilities.
- User education: Educate users on best practices for safe web browsing, such as avoiding clicking on suspicious links or downloading attachments from unknown sources.
- Incident response planning: Develop and test incident response plans to ensure that web application security incidents are identified and addressed in a timely and effective manner.

2.11 Attack tools

Protecting an organization's assets and IT infrastructure requires that you have some idea of how attackers think. Knowing how an attack is conducted and what tools are used will help you build a defense plan. In fact, many organizations use the same tools that attackers use to help identify weaknesses they need to address. It is always better to find weaknesses in your own environment before an attacker does, but it is even more important to quickly remediate that weakness.

Computer criminals and cyberattackers use a number of hardware and software tools to discover exploitable weaknesses and other tools to perform the actual attack. These tools and techniques can include the following:

- Protocol analyzers
- Port scanners
- OS fingerprint scanners
  - Vulnerability scanners
  - Exploit software
  - Wardialers
  - Password crackers
  - Keystroke loggers

Protocol Analyzers

A protocol analyzer or packet sniffer (or just sniffer) is a software program that enables a computer to monitor and capture network traffic, whether on a LAN or a wireless network. Attackers can capture and compromise passwords and cleartext data. Protocol analyzers come in both hardware versions and software versions, or a combination of both. Sniffers operate in promiscuous mode, which means that every data packet can be seen and captured by the sniffer. Sniffers decode the frame and IP data packet, allowing you to see data in cleartext if it has not been encrypted.

Port Scanners

A port scanner is a tool used to scan IP host devices for open ports that have been enabled. Think of a port number as a channel commonly associated with a service. For example, Port 80 is for HTTP web traffic, Port 21 is File Transfer Protocol (FTP), and Port 23 is Telnet, and so on. Request for Comments (RFC) 1700, now superseded by RFC 3232, lists the most common TCP/UDP port numbers and services. (For a complete list of port numbers, refer to the Internet Assigned Numbers Authority [IANA].) Port scanners are used to identify open ports or applications and services that are enabled on the IP host device. This provides attackers with valuable information that can be used in the attack.

OS Fingerprint Scanners

An operating system (OS) fingerprint scanner is a software program that allows an attacker to send a variety of packets to an IP host device, hoping to determine the target device's operating system (OS) from the responses. Whereas network protocols are generally standard, different operating system vendors are free to implement them as they see fit. The packets sent from the OS fingerprint scanner will recognize differences from the various operating systems used in workstations, servers, and network devices. When an IP host device responds, then the OS fingerprint scanner can guess what operating system is installed on the device. Once an attacker knows what OS and version is installed, the better chance he has to use applicable software vulnerabilities and exploits. A software *vulnerability* is a bug or weakness in the program. An *exploit* is something that an attacker can do once a vulnerability is found.

Vulnerability Scanners

A vulnerability scanner is a software program that is used to identify and, when possible, verify vulnerabilities on an IP host device. From this information, a vulnerability scanner compares known software vulnerabilities in its database with what it has just found. The vulnerability scanner lists all known software vulnerabilities and prioritizes them as critical, major, or minor.

For a complete and up-to-date list of known software vulnerabilities and exposures, visit https://cve.mitre.org. The Common Vulnerabilities & Exposure (CVE) list is maintained and managed by the Mitre Corporation on behalf of the U.S. Department of Homeland Security. This list is now referred to as the National Vulnerability Database (NVD).

Exploit Software

Exploit software is an application that incorporates known software vulnerabilities, data, and scripted commands to "exploit" a weakness in a computer system or IP host device. It is a program that can be used to carry out some form of malicious intent. This includes things like a denial of service attack, unauthorized access, a brute-force password attack, or buffer overflow. Remember, software vulnerabilities create a weakness in the system such as a software bug, glitch, or backdoor vulnerability.

An attacker will use exploit software when performing vulnerability assessments and intrusive penetration testing. Vulnerability assessments might identify a weakness; penetration testing positively verifies the weakness by working to exploit it. Therefore, intrusive testing generates malicious network traffic. Penetration testing is what a black-hat or white-hat hacker performs to penetrate a computer system or IP host device. This can lead to gaining system

access as well as access to data, which are the prize that most black-hat hackers are seeking. A white-hat hacker, given permission, performs penetration testing to confirm that a discovered vulnerability is legitimate, resulting in critical risk exposure. White-hat hackers then recommend ways to mitigate the risk exposure as part of the post-mortem penetration testing report.

Wardialers

A wardialer is a computer program that dials telephone numbers, looking for a computer on the other end. The program works by automatically dialing a defined range of phone numbers. It then logs and enters into a database those numbers that successfully connect to the modem. Wardialers are becoming more archaic and less often used due to the rise of digital telephony, IP telephony, or Voice over IP (VoIP). Prior to VoIP, attackers would use wardialers to gain access to private branch exchange (PBX) phone systems in an attempt to obtain dial tone or international dialing capability to commit toll fraud. In addition, an attacker would use a wardialer to identify analog modem signals and gain access to the remote system within an IT infrastructure.

Some wardialers can also identify the operating system running on a computer, as well as conduct automated penetration testing. In such cases, the wardialer runs through a predetermined list of common usernames and passwords in an attempt to gain access to the system.

> A network intruder can use a wardialer to identify potential targets. If the program does not provide automated penetration testing, the intruder can attempt to hack a modem with unprotected logons or easily cracked passwords. A network system administrator can use a commercial wardialer to identify unauthorized modems on an enterprise network. These unauthorized modems can provide attackers with easy access to an organization's internal network and must be controlled or eliminated.

Password Crackers

The purpose of password cracking is to uncover a forgotten or unknown password. A password cracker is a software program that performs one of two functions: a brute-force password attack to gain unauthorized access to a system or recovery of passwords stored as a cryptographic hash on a computer system. A cryptographic hash is an algorithm that converts a large amount of data to a single (long) number. Once mathematically hashed, the hash value can be used to verify the integrity of those data. In a brute-force password cracking attempt, an attacker tries every possible character combination until the "cracked" password succeeds in granting acccess. Dictionary attacks are a subset of brute-force attacks. In a dictionary password attack, hackers try shorter and simpler combinations, including actual words (hence the name of the attack), because such passwords are so common.

Keystroke Loggers

A keystroke logger is a type of surveillance software or hardware that can record to a log file every keystroke a user makes with a keyboard. The keystroke logger might store the log file locally for later retrieval or send it to a specified receiver. Employers might use keystroke loggers to ensure that employees use work computers for business purposes only. However, spyware can also include keystroke logger software, hoping to transmit information such as a password to an unknown third party. (You'll learn about spyware later in this chapter.) As a piece of hardware, a keystroke logger is typically a battery-sized plug that serves as a connector between the user's keyboard and computer. Because the device resembles an ordinary keyboard

plug, it is relatively easy for someone who wants to monitor a user's behavior to hide such a device in plain sight. Besides, workstation keyboards usually plug into the back of the computer, which makes the keystroke logger even harder to detect. As the user types on the keyboard, the keystroke logger collects each keystroke and saves it as text in its own miniature hard drive. Later, the person who installed the keystroke logger must return and physically remove the device in order to access the information the device has gathered.

A keystroke logger software program is usually disguised as a Trojan malicious software program. This malicious software can be delivered by a URL link, PDF file, or ZIP file. As long as an attacker has network access to a computer, he or she can transfer any file, including executable files, to the target computer. Many attackers then use social engineering to trick users into launching the downloaded programs. Users can also unwittingly download keystroke loggers as spyware, which an attacker can then execute as part of a rootkit. (You'll learn more about rootkits later in this chapter.) The keystroke logger program records each keystroke the user types and periodically uploads the information over the Internet to whomever installed the program.

2.12 Counter measure

Countering Malware

Malware provides a platform for attacks on both personal and business networks. Anti-malware measures are the first line of defense against these attacks. You must take steps to prevent the introduction of malware into your environment. It's always better to prevent malware than to have to fix damage caused by malware. You must develop a security program for preventing malware.

Following are six general steps for preventing malware:

- Create an education (information security awareness) program to keep your users from installing malware on your system.
- Post regular bulletins about malware problems.
- Never transfer files from an unknown or untrusted source unless the computer has an anti-malware utility installed. (You'll learn more about anti-malware utilities in a moment.)
- Test new programs or open suspect files on a quarantine computer—one that is not connected to any part of your network—before introducing them to the production environment
- Install anti-malware software, make sure the software and data are current, and schedule regular malware scans to prevent malicious users from introducing malware and to detect any existing malware.
- Use a secure logon and authentication process.

In addition, the following websites can be checked for information about malware:

National Cyber Security Alliance (NCSA)—*www.staysafeonline.org*.
United States Computer Emergency Readiness Team (US-CERT)—*http://us-cert.gov*

Many anti-malware products are available to prevent the spread of all types of malware as well remove malware from infected computers.
These include the following:

BitDefender—*www.bitdefender.com.*
Kaspersky Anti-Virus—*www.kaspersky.com.*
Webroot Antivirus—*www.webroot.com.*
Norton AntiVirus—*www.symantec.com/norton/antivirus.*
ESET Nod32 Antivirus—*www.eset.com.*
AVG Antivirus—*www.avg.com.*
G DATA Antivirus—*www.gdatasoftware.com.*
Avira Antivirus—*www.avira.com.*
McAfee Endpoint Protection—*www.mcafee.com.*
Trend Micro—*www.trendmicro.com.*
Microsoft Security Essentials—*www.microsoft.com/ security_essentials.*

Protecting System with Firewalls

A firewall is a program or dedicated hardware device that inspects network traffic passing through it and denies or permits that traffic based on a set of rules you determine at configuration. A firewall's basic task is to regulate the flow of traffic between computer networks of different trust levels—for example, between the LAN-to-WAN domain and the WAN domain, where the private network meets the public Internet.

There are numerous firewall solutions available. Prominent firewall vendors include the following:

Palo Alto Networks—*www.paloaltonetworks.com.*
Cisco Systems—*www.cisco.com.*
SonicWALL—*www.sonicwall.com.*
WatchGuard Technologies—*www.watchguard.com.*
Check Point—*www.checkpoint.com.*
ZyXEL—*www.zyxel.com.*
Netgear—*www.netgear.com.*
Juniper Networks—*www.juniper.net.*
DLink—*www.dlink.com.*
MultiTech Systems—*www.multitech.com.*